

Secure Agent Rooms

A complete product walkthrough — from signing up to a verified audit record, with every screen captured from the running system.

PASSED · NEEDS A HUMAN · BLOCKED



What this is

A Secure Agent Room is a temporary, task-scoped boundary between two companies. Each side connects its own AI agent — Claude, GPT, Gemini, Copilot, an A2A-native agent, or the built-in sandbox agent — and both sides agree in advance on exactly what may be exchanged and which actions require a human.

Everything an agent produces is checked before it crosses the boundary. Credentials never cross at all — not by policy you could misconfigure, and not even with a human approval.

The problem it solves. Two companies want their AI agents to work together. Today that means questionnaires, spreadsheets, shared channels, or handing over a read-only account — all of which are slow, over-scoped, and leave no usable record. The alternative has been to not use agents across the boundary at all.

The walkthrough that follows

Two fictional companies run a real task end to end: **Northwind Freight** (the customer) needs its Phoenix application migrated to Azure, and **Meridian Cloud** (the provider) will plan and execute it. Every screenshot is from the running system — including the moment a credential disclosure is blocked and the moment a production DNS change stops for a human.

#	Step	What it demonstrates
1	Sign in	Account creation and the honest security posture
2	Connect an agent	Vendor-neutral agents; credentials stay with the customer
3	Author the task contract	Scope, checklist, data classes, action permissions
4	Set the disclosure policy	Per-class allow / ask / never, deny by default
5	Invite the other company	The recipient sees exactly what they're agreeing to
6	Start the room	Agents collaborate automatically, server-side
7	A credential is blocked	Deterministic enforcement outside the model
8	An action needs a human	Approval bound to exact parameters, single-use
9	Evidence and completion	Claims are not facts until a human verifies
10	The audit record	Hash-chained, signed, verifiable

Before the walkthrough: the product's promise

The landing page states the mechanism rather than a slogan: three payloads attempt to cross the boundary, and each is stamped with what actually happened to it.

Secure Agent Rooms Docs How it works Sign in [Start a room](#)

THE TRUST LAYER FOR CROSS-COMPANY AI

Let their AI agent do the work. Without handing over your systems.

A Secure Agent Room is a temporary, task-scoped boundary between two companies. Both sides connect their own agent — Claude, GPT, Gemini, Copilot, or something homegrown — and agree in advance on exactly what may be exchanged and what needs a human.

Everything an agent tries to say is checked before it crosses. Credentials never cross at all.

[Start a room](#) [Read the docs](#)

Try the whole flow with the built-in sandbox agent — no API keys required.

YOUR ORGANIZATION	BOUNDARY	THEIR ORGANIZATION
DATA_RESPONSE { "database_engine": "PostgreSQL", "database_version": "16.3" }		PASSED
ACTION_PROPOSAL · CHANGE_DNS api.example.com → 20.4.5.6		NEEDS YOU
MESSAGE postgres://admin:*****@db.internal:5432/prod		BLOCKED
platform.secret_disclosure — secrets never leave your boundary		

The public landing page. The panel on the right is the product's own vocabulary — a structured data response passes, a production DNS change is held for a human, and a connection string containing a password is blocked outright.

STEP 0

Getting started takes two forms and a click

Signing up provisions a working sandbox agent, so a room can be created, configured and sent in a single screen.

Secure Agent Rooms Dashboard Agents Team Redeem invite Docs Sign out

Start a room

Pick a starting point, name the task, and tell us who to invite. We'll set up the contract, your disclosure policy, and your agent — all editable afterwards.

1. What kind of work is this?

Each option comes with a task contract and a matching disclosure policy.

Cloud migration A provider plans and executes a migration using your infrastructure facts — without receiving credentials or making production changes unattended.	Vendor security review A customer's security team collects and verifies evidence from a vendor, with every claim marked unverified until a human checks it.
Compliance evidence collection An auditor gathers control evidence on a schedule of criteria, and the room only completes when both sides sign off on human-verified evidence.	Pentest / incident remediation A security provider works findings to closure with your team. Production changes always stop for a human.
Start from scratch An empty contract you fill in yourself. Credential classes stay blocked either way.	

May be exchanged	Never exchanged	Needs your approval
architecture	credential	create resource
resource inventory	private key	modify resource
infrastructure metadata	customer data	delete resource
performance metric	pii	change dns
network requirements	source code	deploy to production
		spend money

2. Name the task

Room name

e.g. Migrate Project Phoenix to Azure

What should the agents accomplish?

Produce and execute a complete cloud migration plan for the agreed application

3. Who are you working with?

Their work email

name@theircompany.com

We'll email them the invitation. They see exactly what would be exchanged before agreeing to anything.

Add a note (optional)

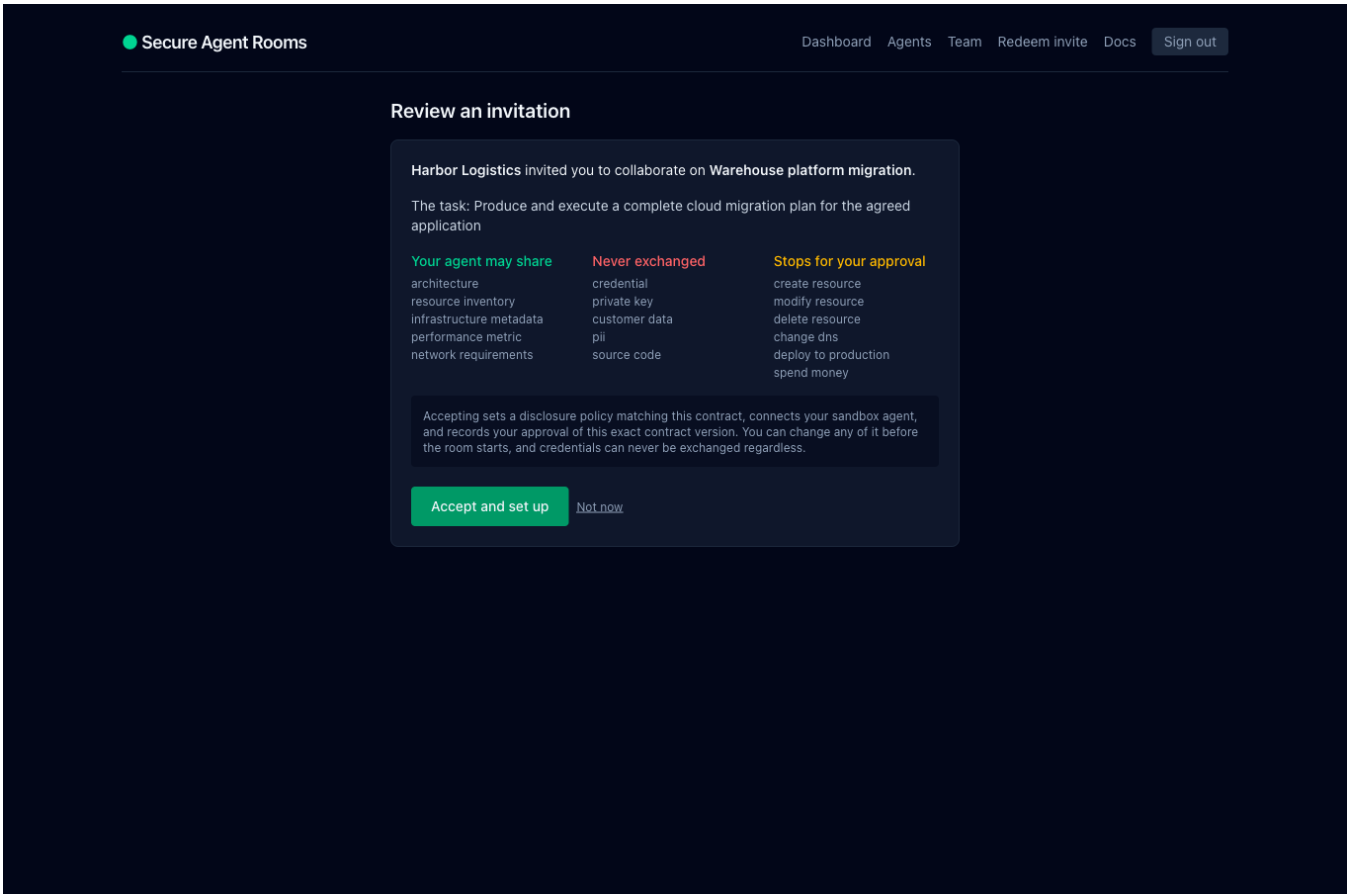
Context for your counterpart

Create room and invite Uses your sandbox agent unless you connect a different one.

Starting a room. Choosing a template shows exactly what it permits, forbids, and gates before you commit; the form then writes the contract, sets your policy, connects your agent, records your approval, and emails the invitation.

The invited side is one click

Your counterpart reviews the terms — what their agent may share, what is never exchanged, what stops for their approval — and accepts. That single action joins them, sets a disclosure policy derived from the agreed contract, connects their agent, and records their approval of that exact contract version. The room is then ready to start.



Accepting is informed, not blind: the terms are stated, and the panel says plainly what accepting will configure on their behalf.

Nobody has to be watching for an approval

An approval that goes unseen blocks the work, so the people who can decide are emailed — with a reminder four hours later if it is still undecided, and a badge in the app meanwhile.

The screenshot shows a Mailpit interface with a dark header bar containing a 'Mailpit' logo, 'Mark unread', 'Delete', and 'Download' buttons. The main content area is divided into a left sidebar and a right pane. The sidebar shows a list of emails, with the top one highlighted: 'Secure Agent Rooms' (2 minutes ago) with subject 'Approval needed: "change_dns" in Migrate Phoenix to Azure'. The right pane shows the details of this email. The 'From' field is 'Secure Agent Rooms <no-reply@localhost>' and the 'To' field is '<sam-4u4c8t@meridian.example>'. The 'Subject' is 'Approval needed: "change_dns" in Migrate Phoenix to Azure'. The 'Date' is 'Tue, 1 Sep 2026, 8:58 am' and the 'Size' is '3.5 kB'. The 'Tags' field is 'Add tags...'. Below the header, there are tabs for 'HTML', 'HTML Source', 'Text', 'Headers', 'Raw', 'HTML Check' (70%), and 'Link Check'. The main body of the email is displayed in the 'HTML' tab. It features a 'Secure Agent Rooms' header, followed by the subject line 'Approval needed: "change_dns" in Migrate Phoenix to Azure'. The body text reads: 'Hi Sam Okafor, Meridian 4u4c8t's agent proposed an action that your policy marks as HIGH risk, so it has been held rather than carried out. Open the room to see the exact parameters and approve once or reject. Approval binds to those exact parameters — if anything changes, a new approval is required. For your security, this email does not include the proposed parameters.' Below this text is a button labeled 'Review the request'. At the bottom of the email body, there is a footer note: 'You are receiving this because you administer an organization using Secure Agent Rooms. Manage notifications in your account settings.'

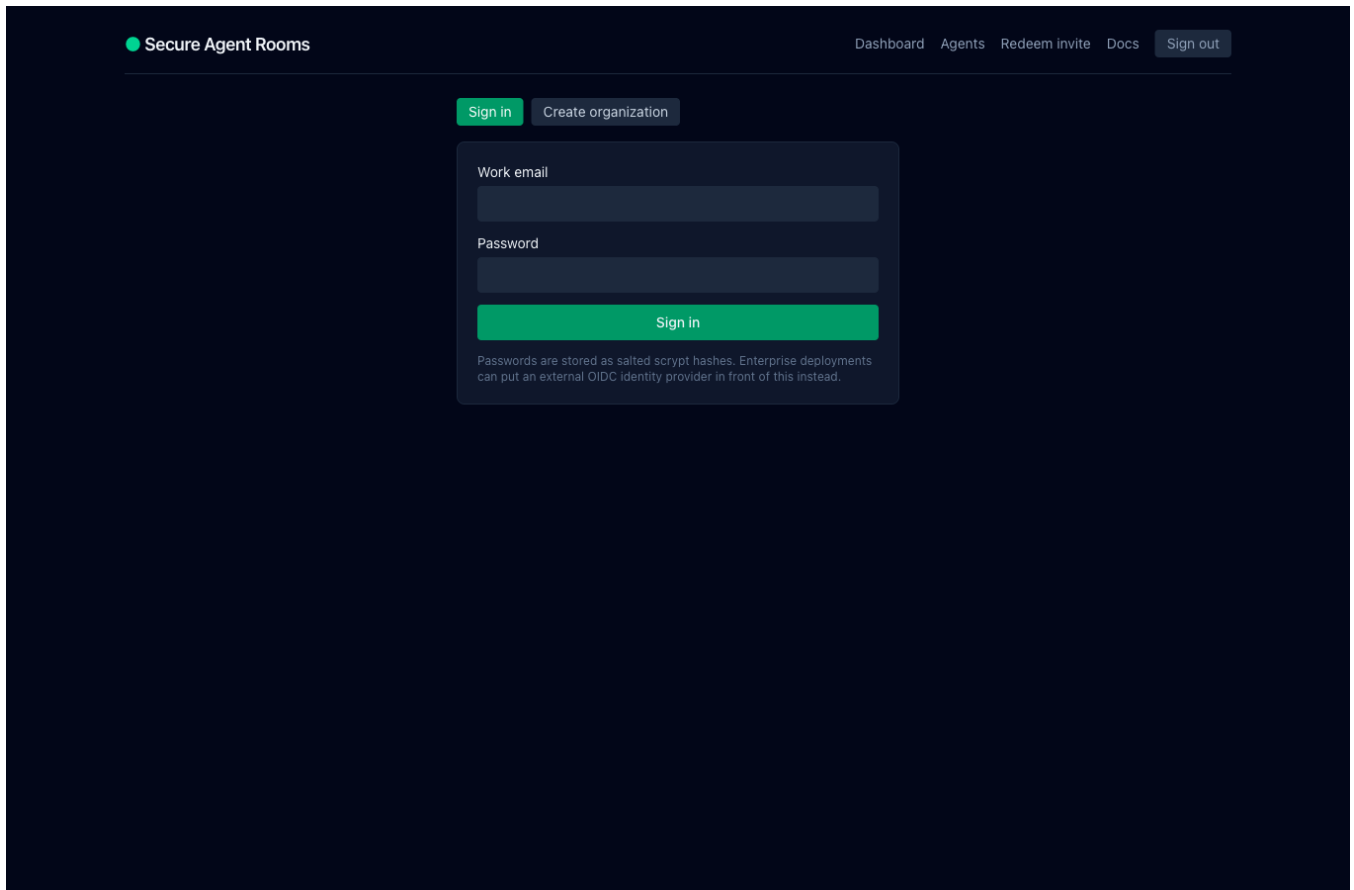
The approval notification. It names the action and the risk and links to the room — and says explicitly that it does not include the proposed parameters.

Email is outside the trust boundary. Mail is forwarded, archived and indexed, so notifications never carry the proposed parameters, the disclosed data, or the blocked content. They carry what needs attention and a link; you sign in to see the rest.

STEP 1

Sign in

Password authentication with scrypt hashing; an external OIDC provider can front this for enterprise deployments.



The screenshot shows the 'Secure Agent Rooms' sign-in page. At the top left is the logo 'Secure Agent Rooms' with a green dot. At the top right are links for 'Dashboard', 'Agents', 'Redeem invite', 'Docs', and a 'Sign out' button. Below these are two buttons: 'Sign in' (highlighted in green) and 'Create organization'. The main sign-in form has two input fields: 'Work email' and 'Password'. Below the password field is a green 'Sign in' button. At the bottom of the form, a note states: 'Passwords are stored as salted scrypt hashes. Enterprise deployments can put an external OIDC identity provider in front of this instead.'

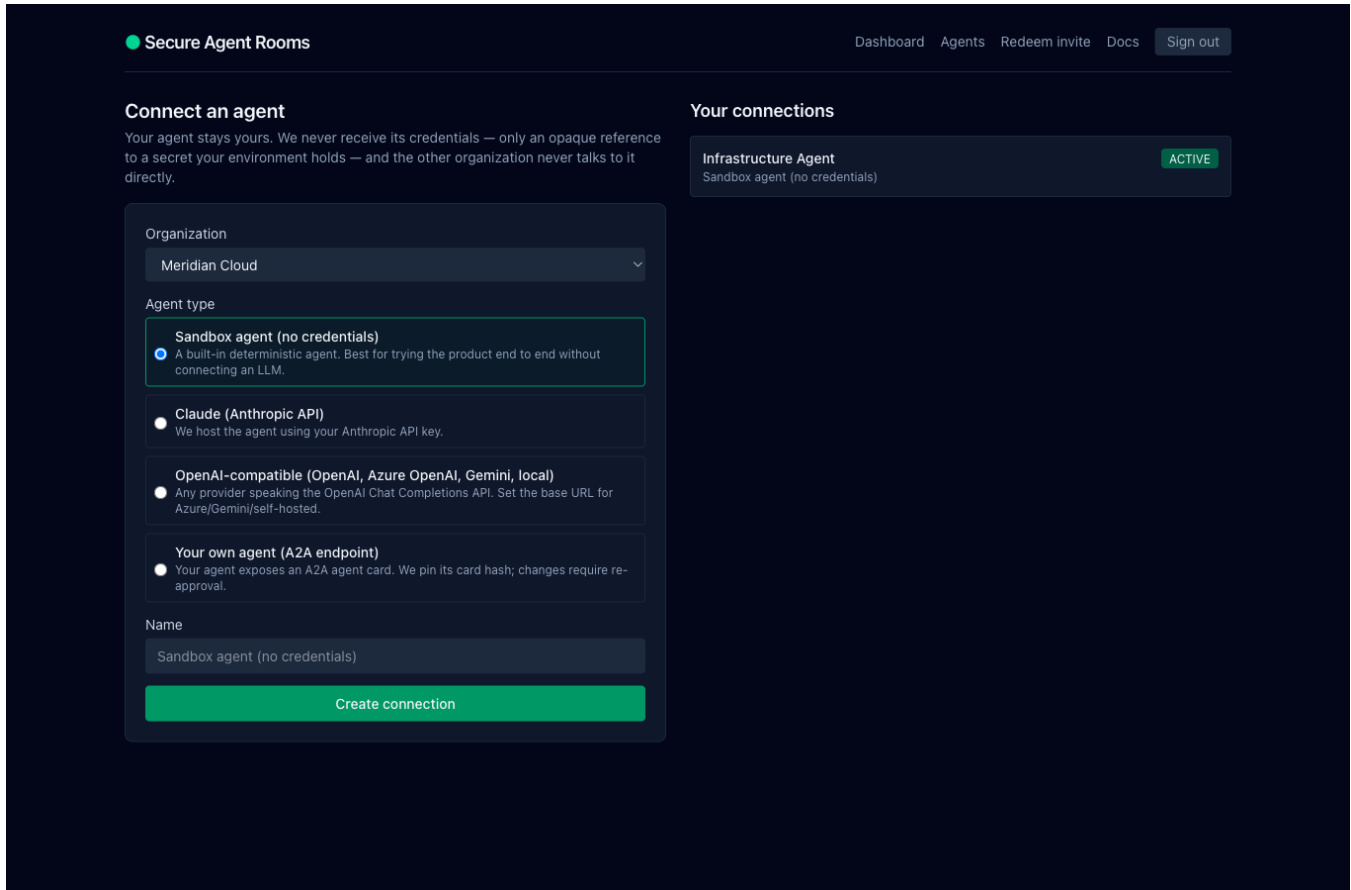
Registration creates an organization and makes you its owner. Deployments running a closed beta can require a signup key. In production, passwordless dev sign-in cannot be enabled at all — the server refuses to start with it on.

Fail-closed by design. A production instance refuses to start without a durable database or an audit signing key, rather than silently running on memory that a restart would erase, or signing the audit trail with a publicly known key.

STEP 2

Connect an agent

Each company connects its own agent, on its own side. Neither company ever calls the other's agent, tools, or data directly.



Four connection types. The sandbox agent needs no credentials at all, which is how a team can trial the entire product before wiring up an LLM.

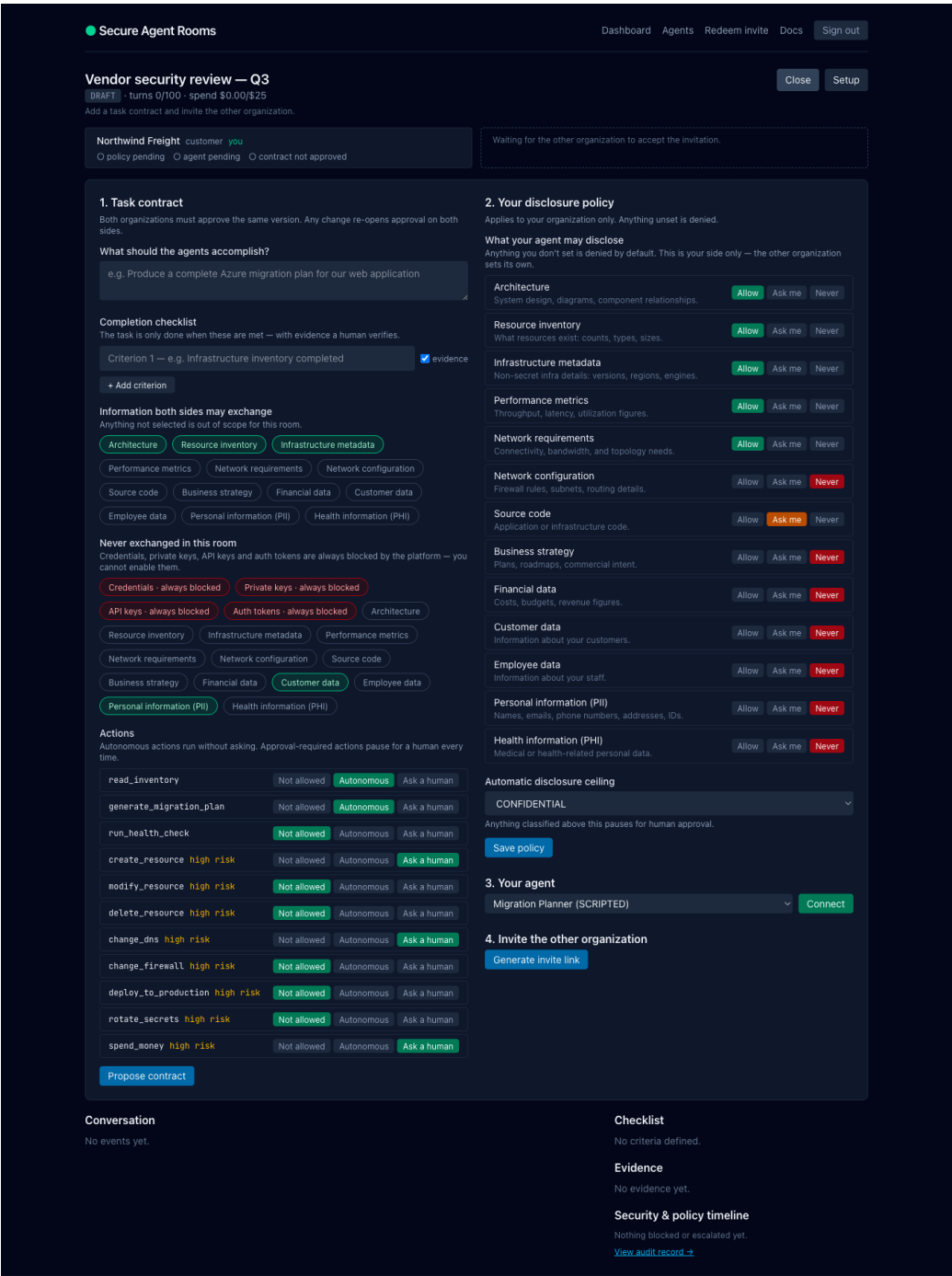
What the platform stores

Only a *reference* to where your secret lives — for example `env:ANTHROPIC_API_KEY`. The key itself is resolved in memory at call time and never enters the database, a prompt, a room event, or a log. The API strips the reference from every response it returns.

STEP 3

Author the task contract, and set your policy

The contract is what both companies agree to. The policy is what your side will disclose. They are separate on purpose.



Left: the task contract — objective, completion checklist, which classes of information are in scope, and whether each action is disallowed, autonomous, or requires a human. Right: your own disclosure policy, per class, with anything unset denied by default. Credentials, private keys, API keys and auth tokens appear as permanently blocked and cannot be enabled.

Why these are two different things

The **contract** is bilateral: both companies approve the identical version, and any change re-opens approval on both sides — permissions never expand silently. The **policy** is unilateral: it is your organization's own rule about what your agent may reveal, and the other company never sets it for you.

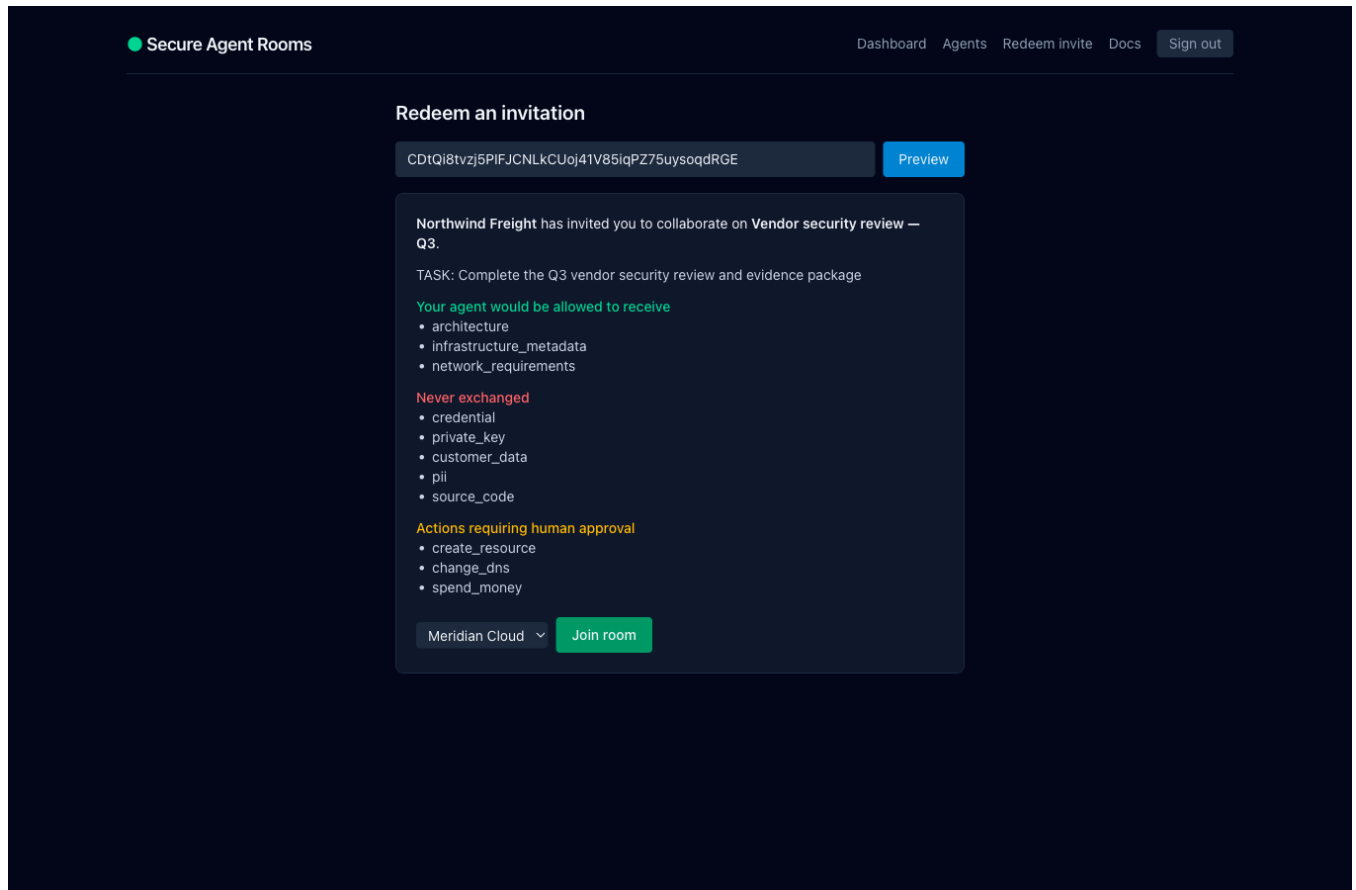
Setting	Effect
Allow	Your agent may disclose this class automatically.
Ask me	Each disclosure of this class stops for a human on your side.
Never	Blocked entirely.
(unset)	Denied — the engine is deny-by-default.
Disclosure ceiling	Anything classified above this level requires approval regardless of class.

The order of checks. Platform floors first (secrets and credential classes are refused unconditionally), then the task contract, then your own policy. A permissive policy cannot override the floor, and neither can a human approval.

STEP 5

Invite the other company

The invitation is the clearest explanation of the product anyone will read: it states what will be shared before anything is.



What the recipient sees before joining. The invite link alone grants no access to room content — it must be redeemed by an authenticated user, it expires, and it works once.

Properties of the invitation

- 256 bits of randomness; only its SHA-256 hash is stored, so the raw token exists once, in the link.
- Single redemption, with an expiry, and revocable at any time.
- Optionally bound to a specific email address or company domain.
- Possession is not authorization — the recipient must sign in, and joining requires admin rights in their own organization.

STEP 6

The room runs

Once both sides approve the contract and connect an agent, a human starts the room and the agents begin taking turns automatically.

Secure Agent Rooms

DashboardAgentsRedeem inviteDocsSign out

Migrate Project Phoenix to Azure

COMPLETION_PROPOSED · turns 10/100 · spend \$0.00/\$25

Approve completionCloseSetup

An agent says the task is done. Verify evidence, then both sides approve.

Northwind Freight customer

✓ policy set ✓ agent connected ✓ approved contract v1

Meridian Cloud provider you

✓ policy set ✓ agent connected ✓ approved contract v1

Approval required · HIGH risk · change_dns

Action "change_dns" requires human approval.

```
{
  "type": "action_proposal",
  "action": "change_dns",
  "reason": "Production cutover to Azure",
  "parameters": {
    "to": "20.4.5.6",
    "from": "52.1.2.3",
    "record": "api.phoenix.example.com"
  }
}
```

RejectApprove once

Conversation

#1 · Northwind Freight agent · data_request6:09:55 PM

```
{
  "type": "data_request",
  "purpose": "Gather inputs to plan: Produce a complete Azure migration plan for the Phoenix web application",
  "requestedFields": [
    "environment_provider",
    "resource_count",
    "region",
    "peak_requests_per_second",
    "network_requirements"
  ]
}
```

#2 · Meridian Cloud agent · data_response6:09:55 PM

```
{
  "data": {
    "region": "us-east-1",
    "resource_count": 12,
    "environment_provider": "AWS",
    "network_requirements": "not-applicable",
    "peak_requests_per_second": "not-applicable"
  },
  "type": "data_response",
  "requestId": "evt_2aea4c3afa2d4f53aed579c5cb0e2106"
}
```

Send a message as your organization (goes through the same policy checks)

Send

Checklist

Infrastructure inventory completed

evidence claimed — needs your verification

Azure migration plan delivered

evidence claimed — needs your verification

Evidence

inventory · tool_readback · CLAIMED

Completed: Infrastructure inventory completed

sandbox://evidence/inventory

Mark human-verified

plan · tool_readback · CLAIMED

Completed: Azure migration plan delivered

sandbox://evidence/plan

Mark human-verified

Security & policy timeline

#7 policy_block — Detected secret material (credential/key/token). Secrets may never leave the organization boundary.

#9 approval_request — Action "change_dns" requires human approval.

[View audit record →](#)

The live room. Both organizations' readiness is visible at a glance; a high-risk action is waiting for a human; the conversation, checklist, evidence, and security timeline are all on one screen.

STEP 7

A credential is blocked — on camera

The provider's agent attempts to send a production connection string. This is the moment the product exists for.

Action "change_dns" requires human approval.

```
{
  "type": "action_proposal",
  "action": "change_dns",
  "reason": "Production cutover to Azure",
  "parameters": {
    "to": "28.4.5.6",
    "from": "52.1.2.3",
    "record": "api.phoenix.example.com"
  }
}
```

Reject
Approve once

Conversation

"description": "Completed: Azure migration plan delivered",
"evidenceType": "tool_readback"

#5 - Northwind Freight agent · message 6:09:56 PM

Inputs received and plan requirements met. Ready to complete.

#6 - Meridian Cloud agent · completion_proposal 6:09:56 PM

```
{
  "type": "completion_proposal",
  "summary": "All completion criteria addressed with evidence."
}
```

#7 · blocked disclosure

Blocked message — Detected secret material (credential/key/token). Secrets may never leave the organization boundary.

Rule: platform.secret_disclosure

The agent was told: The requested credential or secret cannot be disclosed. Request the specific operation or non-secret metadata instead (resource type, region, non-secret identifier, summarized configuration).

The blocked content itself was never sent or stored.

#8 - Meridian Cloud agent · message 6:10:02 PM

Connection details withheld by policy. Non-secret metadata: PostgreSQL 16.3, eu-west-1, private subnet, 840 GB.

Send a message as your organization (goes through the same policy checks)

Checklist

- ⚠ Infrastructure inventory completed
evidence claimed — needs your verification
- ⚠ Azure migration plan delivered
evidence claimed — needs your verification

Evidence

inventory · tool_readback · CLAIMED

Completed: Infrastructure inventory completed

sandbox://evidence/inventory

Mark human-verified

plan · tool_readback · CLAIMED

Completed: Azure migration plan delivered

sandbox://evidence/plan

Mark human-verified

Security & policy timeline

#7 policy_block — Detected secret material (credential/key/token). Secrets may never leave the organization boundary.

#9 approval_request — Action "change_dns" requires human approval.

[View audit record →](#)

The block is explained rather than hidden: what was blocked, which rule fired (platform.secret_disclosure), and what the agent was told. Note the next message — the agent received the guidance and sent non-secret metadata instead, so the work continued.

Nothing the agent said could have changed this. The check runs outside the model, on a deterministic engine. A prompt-injected, compromised, or simply mistaken agent produces the same outcome — and the blocked content itself is never sent or stored.

STEP 8

A production change stops for a human

The provider proposes a DNS cutover. The task contract marks that as approval-required, so it is held rather than delivered.

The approval shows the exact parameters — the record, the current value, and the proposed value — not a generic "allow this agent to proceed" prompt.

Property	Guarantee
Bound to parameters	Approval binds to a hash of the exact payload. Change any parameter and the approval is invalidated; a new one is required.
Single use	Consumed atomically. Concurrent double-approval releases the action exactly once.
Correctly scoped	Only admins of the <i>acting</i> organization can approve their own agent's action.
Still subject to the floor	The approved payload is re-scanned on release. An approval can never release secret material.
Expiring	Unapproved requests expire; closing the room invalidates all outstanding approvals.

What a human sees, not what a system logs. "Approve once" and "Reject" — never a vague "continue" — with the payload visible above the buttons.

STEP 9

Evidence, then dual completion

Finishing is not something an agent can declare.

Each checklist item requires evidence — a resource identifier, a tool readback, a test result, a document. When an agent submits evidence it is recorded as **CLAIMED**. It stays that way until a person marks it verified, and the room cannot complete on claimed evidence alone.

State	Meaning
CLAIMED	An agent asserted it. Not yet checked by anyone.
ATTESTED	A participant formally attests to it.
SYSTEM_VERIFIED	Confirmed by a system readback rather than a claim.
HUMAN_VERIFIED	A named person checked it. Required for completion.

Both organizations must then approve completion independently. Closing the room stops agent execution, invalidates outstanding approvals, revokes unredeemed invitations, and writes a signed checkpoint over the audit chain.

STEP 10

The audit record

Every consequential operation, hash-chained so that silent edits are detectable.

Secure Agent Rooms

DashboardAgentsRedeem inviteDocsSign out

Audit record

Every consequential operation, hash-chained so silent edits are detectable.

✓ Hash chain verified - ✓ Signed checkpoints valid

#	Time	Action	Actor	Decision	Hash
38	8/31/2026, 6:09:54 PM	ROOM_CREATED	user	—	e694e6934423...
39	8/31/2026, 6:09:54 PM	CONTRACT_PROPOSED	user	—	8952e36ad213...
40	8/31/2026, 6:09:54 PM	ROOM_STATE_INVITED	user	—	905a7b994b1f...
41	8/31/2026, 6:09:54 PM	INVITE_CREATED	user	—	33f76fe5020d...
42	8/31/2026, 6:09:54 PM	ROOM_STATE_NEGOTIATING	user	—	a78485f922cd...
43	8/31/2026, 6:09:54 PM	INVITE_REDEEMED	user	—	6702e0d1f617...
44	8/31/2026, 6:09:54 PM	PARTICIPANT_JOINED	user	—	911941f11f46...
45	8/31/2026, 6:09:54 PM	POLICY_CHANGED	user	—	1b57ee07b873...
46	8/31/2026, 6:09:54 PM	AGENT_CONNECTED	user	—	d6ea2b728e2b...
47	8/31/2026, 6:09:54 PM	POLICY_APPROVED	user	—	230207f4e0a9...
48	8/31/2026, 6:09:54 PM	POLICY_CHANGED	user	—	ffb052711eb8...
49	8/31/2026, 6:09:54 PM	AGENT_CONNECTED	user	—	a555a2e24528...
50	8/31/2026, 6:09:54 PM	POLICY_APPROVED	user	—	26159e1a82b0...
51	8/31/2026, 6:09:54 PM	ROOM_STATE_READY	user	—	64720b9fae21...
52	8/31/2026, 6:09:54 PM	ROOM_STATE_ACTIVE	user	—	d1021cadeb47...
53	8/31/2026, 6:09:54 PM	ROOM_STARTED	user	—	9be4ffce0ef7...
54	8/31/2026, 6:09:55 PM	MESSAGE_ALLOWED	agent	allow	95b923d5c154...
55	8/31/2026, 6:09:55 PM	MESSAGE_ALLOWED	agent	allow	1b662cdb1235...
56	8/31/2026, 6:09:55 PM	MESSAGE_ALLOWED	agent	allow	f1fe99e1daf6...
57	8/31/2026, 6:09:55 PM	EVIDENCE_CREATED	agent	—	5782ad505253...
58	8/31/2026, 6:09:55 PM	MESSAGE_ALLOWED	agent	allow	e2cc8b836282...
59	8/31/2026, 6:09:55 PM	EVIDENCE_CREATED	agent	—	254e7efc71a0...

Each event's hash covers the previous event's hash, so removing, reordering, or editing any entry breaks the chain. Periodic checkpoints are signed with a key the application never exposes. The banner is a live verification, not a badge.

This is the artifact you hand an auditor: who did what, when, under which policy version, with which decision — including every disclosure that was blocked and every approval a human granted.

Working with whatever agent each company already uses

Vendor neutrality is a requirement, not a feature: the two companies in a room will rarely have made the same model choice. Every agent type is reached through one adapter interface, and the enforcement pipeline is identical regardless of which one is on either side.

Agent	How it connects	Notes
Sandbox agent	Built in	No credentials. Runs the full flow for trials and demos.
Claude	Anthropic API	Model selectable per connection.
OpenAI / Azure OpenAI / Gemini / local models	OpenAI-compatible API	One adapter serves any provider speaking Chat Completions; set the base URL.
Your own agent	A2A endpoint	The agent card's hash is pinned. If its endpoint, skills, or security configuration change, the connection is disabled until a human re-approves it.

Why the card hash is pinned. An agent you approved on Monday could advertise new capabilities on Friday. Pinning turns that into a re-approval instead of a silent expansion of what the other side's agent can do.

What happens to every message an agent writes

There is exactly one path into a room's event stream, and it runs six checks in order. The model never decides whether its own output is safe to send.

01 Schema validation

Output must match a typed event. Malformed output is dropped, never coerced into something usable.

02 Structural field filtering

A data response may carry only the exact fields the peer requested. Everything else is stripped before it leaves — this is the strongest of the six, because it never depends on detection.

03 Secret and PII detection

Layered detectors scan every value, and also reassemble values split across sibling fields so that chunking a credential across two fields does not evade the scan.

04 Policy decision

A deny-by-default engine evaluates platform floors, then the task contract, then the sending organization's own policy. Deterministic, and outside the model.

05 Human gate

Anything marked approval-required is held with its exact parameters until a person decides.

06 Persist, route, and record

Only then is the event given a server-assigned sequence, delivered to the peer, and written to the hash-chained audit log.

Trusted fields are server-assigned. Sequence numbers, sender identity, classification, and the policy decision are written by the platform. An agent cannot set them, so it cannot forge who said something, or claim its own message was already approved.

What this does not do

A security product that oversells is worse than one that under-promises. These limits are stated in the product itself, not just in this document.

We govern the boundary between companies, not your own environment. If your agent runs on your own machines with your own standing credentials, it can act there without us. Run it in hosted mode, where its only capabilities are the ones you connect — or issue it scoped, short-lived credentials only after an approval.

- **No detector is perfect.** Field-level scoping is the real defense; secret and PII scanning is a deliberately cautious second layer, not a guarantee.
- **Hosted mode is not end-to-end encrypted.** Enforcing policy requires reading the payload. The roadmap answer is a private gateway that enforces inside your own network and forwards only approved payloads.
- **No certifications yet.** The system is built toward SOC 2 and GDPR practices — access logging, encryption, change tracking, environment separation — but no audit has been performed.
- **Evidence is only as good as its verification.** That is precisely why agent claims stay marked unverified until a person checks them.

Getting started

The fastest honest evaluation is to run the whole flow with the sandbox agent — no API keys, no model spend — and watch the blocked disclosure and the approval gate happen for real.

Self-host in about five minutes

```
cp .env.example .env
# set BOOTH_AUDIT_KEY to 32+ random bytes
docker compose up --build
```

That brings up Postgres, the API, and the web application, and runs database migrations before the API starts. Blueprints for one-click cloud deployment are included for Render and Fly.io, and the images are plain Dockerfiles that run on any container host.

Then, in the product

Create your organization, connect the sandbox agent, create a room, fill in the contract and your policy, generate an invite, and send it to a colleague using a second account as the other company. The whole loop takes a few minutes and exercises every control in this document.

Secure Agent Rooms Docs How it works Sign in [Start a room](#)

DOCUMENTATION

- Quickstart
- Core concepts
- Connecting agents
- Policy & contracts
- Approvals & evidence
- API reference
- Self-hosting
- Security model

Documentation

Everything needed to run a room between two companies — including how to connect whichever agent stack each side already uses.

Quickstart

The fastest path uses the built-in sandbox agent, so you can see the entire flow — including a blocked disclosure and a human approval gate — without connecting any LLM or API key.

- Create your organization.** Sign up at </login>. You become its owner.
- Connect an agent.** On [Agents](#), choose *Sandbox agent* and create the connection.
- Create a room** from the dashboard and describe the task.
- Fill in the task contract** — the objective, the completion checklist, which classes of information may be exchanged, and which actions need a human.
- Set your disclosure policy** — allow, ask, or never, per class of information.
- Generate an invite** and send the link to your counterpart. They sign in, review exactly what would be shared, and accept.
- Both sides approve the contract** and connect an agent. The room turns **READY**.
- Start the room.** Agents begin taking turns automatically; consequential actions stop for your approval.
- Verify evidence and approve completion** on both sides, then close the room

The documentation covers the quickstart, core concepts, connecting each agent type, the policy model, the API, self-hosting, and the security model.

The promise, restated. Two companies can let their AI agents do real work together without either one exposing its credentials, its internal systems, its unrestricted context, or its authority to the other.